

Sumário

1. Resumo executivo e veredicto	1
2. Metodologia da auditoria	2
3. Prontidão para divulgação nas redes sociais	2
4. Prontidão para uso por muitas pessoas	3
5. Segurança e conformidade	4
6. Evidências de produção (E2E)	4
7. Riscos e limitações conhecidas	5
8. Plano de ação recomendado	6

1. Resumo executivo e veredicto

Esta auditoria avaliou o Diário da Riqueza sob duas perguntas feitas pelo operador: o aplicativo está pronto para ser divulgado nas redes sociais, e está pronto para ser usado por muitas pessoas ao mesmo tempo? A análise combinou quatro frentes de verificação: revisão do código-fonte (metadados, PWA, APIs, autenticação), testes diretos em produção (latências, cache de CDN, cabeçalhos), navegação end-to-end automatizada simulando um usuário real do primeiro clique até o registro diário, e varredura de segurança no pacote JavaScript entregue ao navegador.

PRONTA

Veredicto geral — pode divulgar

346

Testes automatizados, 0 falhas

0

Segredos expostos no bundle público

O veredicto é **positivo: o aplicativo está pronto para divulgação**. O fluxo essencial — chegada pela landing page, criação do diário em 5 passos, registro do dia com XP e conquista — funciona de ponta a ponta em produção, inclusive offline. Durante a própria auditoria, três lacunas que fragilizariam a primeira impressão pública foram identificadas e corrigidas no mesmo dia: inexistência de páginas de Política de Privacidade e Termos de Uso, ausência de sitemap.xml para indexação e um erro 404 sem identidade visual. Todas corrigidas, implantadas e verificadas em produção.

Quadro de prontidão por dimensão

Dimensão	Nota	Situação verificada
Funcionalidade e qualidade	9,5	346 testes verdes; E2E limpo, zero erros de console
PWA e funcionamento offline	9,5	Instalável; service worker ativo; recarga offline funcional
Compartilhamento social (SEO/OG)	9,0	og:image 1200×630 real; cartão Twitter completo; pt-BR
Segurança	9,0	Admin com auth e rate limit; webhook timing-safe; bundle limpo
Confiança e conformidade (LGPD)	9,0	Privacidade e Termos publicados; dados 100% locais
Escalabilidade	8,5	Local-first escala bem; CDN cache ativo; Hobby tem limite de banda
Acessibilidade	7,5	Boa navegação semântica; zoom de página bloqueado (ajuste fino)

Quadro 1 — Scorecard consolidado da auditoria (notas de 0 a 10).

2. Metodologia da auditoria

A avaliação foi executada em quatro camadas complementares, para que o veredicto não dependa de uma única fonte de evidência. A camada de código revisou os arquivos responsáveis por metadados, manifesto PWA, robots.txt, rotas de API, autenticação administrativa e componentes públicos. A camada de infraestrutura mediu tempos de resposta reais das rotas críticas em produção, comportamento do cache de CDN e disponibilidade dos arquivos estáticos (ícones, manifest, service worker).

A camada de experiência simulou um usuário novo por navegador automatizado: abriu a landing page, percorreu o onboarding completo (nome, meta financeira de R\$ 100.000 com prazo 31/12/2030, aparência), criou o diário, registrou uma entrada com aprendizado e reflexão, recebeu o feedback de gamificação (+90 XP e conquista Primeiro Passo) e passou por testes de recarga offline e viewport móvel de 390 pixels. Por fim, a camada de segurança varreu o bundle JavaScript público procurando segredos: senha administrativa, credenciais Cakto, token Vercel e chaves de API.

3. Prontidão para divulgação nas redes sociais

Quando um link é compartilhado no WhatsApp, Instagram, Facebook ou X, a plataforma busca as meta tags Open Graph para montar o cartão de preview. O Diário da Riqueza entrega o conjunto completo: título e descrição em português, imagem de 1200×630 pixels (47 KB, PNG real verificado), texto alternativo descritivo, localização pt_BR e cartão Twitter no modo summary_large_image com imagem própria. Isso significa que quem recebe o link vê um cartão profissional com a identidade preto e dourado — não um link nu.

A landing page em si funciona como página de conversão para tráfego frio: proposta de valor acima da dobra, chamada "Começar gratuitamente" repetida em três pontos, seção de transparência ("o que a ferramenta não promete") que protege a credibilidade, prova social permanente com o Mural dos Fundadores e o letreiro vermelho rolante com 76 nomes, e rodapé com todos os canais do criador. Os bots sociais (Twitterbot, facebookexternalhit) estão expressamente permitidos no robots.txt, enquanto painel administrativo e APIs permanecem fora dos índices.

Verificações de compartilhamento social

Item	Resultado	Detalhe
og:image	Aprovado	PNG 1200×630, 47 KB, servida com 200 e alt text
twitter:card	Aprovado	summary_large_image + imagem e descrição próprias
Título e descrição	Aprovado	Únicos, em pt-BR, com palavras-chave do nicho
robots.txt	Aprovado	Permite bots sociais; bloqueia /admin e /api
sitemap.xml	Aprovado	Criado nesta auditoria (3 URLs indexáveis)
Páginas legais	Aprovado	/privacidade e /termos criadas e linkadas no rodapé
Compartilhar no app	Aprovado	ShareDialog com navigator.share para redes

Quadro 2 — Itens de prontidão social verificados em produção.

Um detalhe que costuma passar despercebido: a divisa de entrada de quem chega das redes é a página inicial carregada pelo CDN com TTFB de 87 milissegundos na segunda visita e cerca de 1,3 s no primeiro acesso (start a frio do servidor sem fio). Para padrão de rede social isso é confortável, e o cartão de preview bem-feito é o que sustenta a taxa de cliques.

4. Prontidão para uso por muitas pessoas

A arquitetura é a maior aliada aqui: por ser local-first, cada usuário carrega seus dados no próprio dispositivo (IndexedDB) e o servidor não armazena nada de conteúdo. Não existe banco de dados central para estourar, não existe autenticação de usuários para escalar, e cada visita custa entrega estática na borda da Vercel. Um pico de dez mil visitas simultâneas degrada muito menos do que em uma aplicação tradicional com backend e banco.

A única rota pública que consulta serviço externo é a do Mural dos Fundadores, e ela foi projetada para isso: cache duplo (memória de 5 minutos no servidor + CDN com s-maxage de 300 segundos e stale-while-revalidate de 30 minutos). A auditoria confirmou o cache de CDN em operação — a segunda chamada consecutiva retornou HIT sem tocar a origem. Mesmo se a Cakto ficar indisponível, a rota responde 200 com estado honesto, sem derrubar a página.

87 ms TTFB da home no CDN (2ª visita)	HIT Cache de CDN na rota /api/founders	390 px Mobile testado: sem scroll horizontal
---	--	--

O plano Vercel Hobby tem 100 GB de banda mensal. Com primeira carga em torno de 1 MB por visitante novo (visitas recorrentes consomem bem menos por causa do cache do service worker), isso corresponde a dezenas de milhares de novos acessos por mês — folga confortável para um lançamento em redes sociais. Se o projeto crescer além disso, o upgrade Pro é operacionalmente trivial: nenhuma mudança de código é

necessária.

O funcionamento offline foi provado em produção: com a rede desligada no navegador, a recarga entregou o shell completo do aplicativo a partir do cache (estratégia network-first para navegações, cache-first para estáticos e stale-while-revalidate para o restante). Um usuário que salva o app na tela inicial do celular continua usando todas as funções principais sem internet — argumento de venda que merece destaque na divulgação.

5. Segurança e conformidade

A superfície administrativa ficou bem protegida: o painel /admin responde 307 e exige login com e-mail e senha, comparação timing-safe em ambos os campos, sessão assinada por HMAC com cookie httpOnly de 8 horas e limite de 5 tentativas por 15 minutos por IP. O webhook da Cakto valida um token compartilhado com comparação timing-safe, e todas as credenciais vivem exclusivamente em variáveis de ambiente do servidor.

A varredura do bundle público procurou a senha administrativa, o e-mail de administração, o token Vercel e segredos da Cakto: nada encontrado. A única ocorrência do identificador "clodoaldo608" é o link público do Linktree no rodapé, de propósito. Em paralelo, as páginas de Política de Privacidade e Termos de Uso publicadas nesta auditoria documentam em linguagem clara o tratamento local-first dos dados, o papel da Cakto nos pagamentos, a política de exibição do mural e os direitos do titular na LGPD — com canal de contato e prazo de resposta.

Resta uma dívida de segurança operacional, já sinalizada antes e mantida no plano de ação: a senha administrativa atual tem apenas oito dígitos numéricos. O rate limit torna força bruta impraticável no curto prazo, mas a troca por uma senha longa com letras, números e símbolos é um incremento de proteção de custo zero.

6. Evidências de produção (E2E)

A tabela a seguir consolida as verificações executadas diretamente contra o ambiente de produção durante a auditoria. Tempos medidos em rede real; o E2E de usuário foi feito em navegador automatizado com coleta de erros de console ao longo de toda a sessão.

Verificação	Resultado	Medição
Home em produção	200	1,36 s a frio; 87 ms TTFB em cache
manifest.webmanifest	200	Instalável, standalone, ícone maskable
Service worker	Ativo	sw.js registrado; cache diario-riqueza-v1
Recarga offline	OK	Shell completo servido sem rede
og:image	200	PNG 1200×630, 47 KB
/api/founders	200	2,6 s a frio; HIT de CDN depois
/admin sem sessão	307	Redireciona para login; sem vazamento
Onboarding 5 passos	OK	Nome, meta, pasta, tema, criação
Registro diário	OK	+90 XP, conquista Primeiro Passo
Mobile 390 px	OK	Sem scroll horizontal; bottom nav
Rotas legais novas	200	/privacidade, /termos, /sitemap.xml
404 com marca	404	Página personalizada com CTA para a home

Quadro 3 — Síntese das evidências coletadas em produção.

7. Riscos e limitações conhecidas

Nenhum bloqueador permanece, mas há pontos que merecem acompanhamento consciente. São limitações conhecidas, documentadas e com mitigação definida — a lista existe para que a divulgação aconteça com clareza sobre o que o produto é hoje, e não por surpresa depois.

- **Start a frio do serverless:** a primeira visita em um período ocioso pode levar de 1,3 s (home) a 2,6 s (/api/founders) a mais. O cache de CDN elimina o efeito para todo mundo que chega em seguida; mitigação natural com tráfego de redes.
- **Limite de banda do plano Hobby (100 GB/mês):** suficiente para o lançamento, mas um vídeo viral muito grande pode exigir o upgrade Pro no meio do mês. Custo baixo, mudança de um clique.
- **Sem analytics ainda:** hoje não há medição de visitantes, origem de tráfego nem conversão da landing. Para divulgação profissional, instalar o Vercel Analytics (sem cookies, LGPD-friendly) deveria ser o primeiro passo pós-auditoria.
- **Zoom de página bloqueado no navegador:** userScalable=false impede pinça de zoom, o que penaliza usuários com baixa visão. O app já é integralmente usável, mas liberar o zoom (ou oferecer ajuste de fonte) fecharia essa diferença de acessibilidade.
- **Recriar conta em outro dispositivo:** bug conhecido e de baixa severidade no fluxo de quem já tinha dados e tenta criar conta novamente em aparelho novo; dados locais não migram sozinhos — o backup/exportação cobre o cenário.

Nenhuma dessas limitações impede a divulgação; todas têm caminho de resolução mapeado no capítulo seguinte.

8. Plano de ação recomendado

Com o veredicto positivo, o plano abaixo ordena os próximos investimentos por impacto sobre o objetivo de crescer com redes sociais. Os itens P1 devem preceder a primeira campanha relevante; os demais podem acompanhar o ritmo de crescimento.

Prioridade	Ação	Esforço	Impacto
P1	Instalar Vercel Analytics (visitantes, origem, conversão)	Baixo	Alto
P1	Trocar a senha admin por senha longa com símbolos	Baixo	Médio
P2	Domin próprio (ex.: diariodariqueza.com.br) + redirecionamento	Baixo	Alto
P2	Monitoramento de uptime com alerta (UptimeRobot/Better Stack)	Baixo	Médio
P2	Recriar o og:image com print real do app (prova visual maior)	Médio	Médio
P3	Liberar zoom da página e revisar contraste em modo claro	Baixo	Médio
P3	Testes em iOS Safari físico (instalação PWA e notificações)	Médio	Médio

Quadro 4 — Ações recomendadas, ordenadas por prioridade.

Conclusão: o Diário da Riqueza chega ao momento de divulgação com base técnica sólida — testes verdes, produção estável, prova social no ar e documentação legal publicada. O próximo salto não é de engenharia, e sim de distribuição: medir (analytics), profissionalizar o endereço (domínio próprio) e iterar a mensagem com o que os números mostrarem. A fundação técnica está pronta para receber o tráfego.